

# RECON & DEFENSE-DETECTION TOOL CHEAT SHEET

Every tool from your lab lecture, plus the tools working pentesters reach for next — organized by what each one actually detects.

Legend: **YES** = used directly in your lecture/lab session | **ADD** = professional tool worth adding to your kit next.

LEVEL: Junior / Foundational | SCOPE: Authorized targets only

---

## How this sheet is organized

Tools are grouped by what they're used to discover — DNS/network layout, load balancers, WAFs, firewalls, and antivirus/endpoint defenses — matching the order you'd actually use them on an engagement. Every command shown is a safe starting point, not a full option list; run `--help` on any tool before using it against a real target.

### 1 — DNS & Network Recon

Map the target's IP footprint before anything else

| Tool                          | What it's for                                                                             | Example / starter command                 | Used in lecture? |
|-------------------------------|-------------------------------------------------------------------------------------------|-------------------------------------------|------------------|
| <b>nslookup</b>               | Quick DNS lookup; multiple A records hint at load balancing/CDN                           | <code>nslookup itpro.tv</code>            | YES              |
| <b>dig</b>                    | More detailed/scriptable DNS lookups than nslookup                                        | <code>dig itpro.tv +noall +answer</code>  | YES              |
| <b>whois</b>                  | Identify who owns an IP/domain and which ASN/cloud provider it belongs to                 | <code>whois 13.32.0.1</code>              | ADD              |
| <b>dnsenum</b>                | Automates DNS enumeration: records, zone transfers, subdomain brute-force                 | <code>dnsenum target.com</code>           | ADD              |
| <b>Amass</b>                  | OWASP tool for deep subdomain/asset discovery; finds forgotten origin servers             | <code>amass enum -d target.com</code>     | ADD              |
| <b>Sublist3r</b>              | Fast subdomain enumeration using search engines & certificate logs                        | <code>sublist3r -d target.com</code>      | ADD              |
| <b>crt.sh / SSL cert logs</b> | Certificate Transparency search — often reveals real origin hostnames hidden behind a CDN | <code>https://crt.sh/?q=target.com</code> | ADD              |

### 2 — Load Balancer & CDN Detection

Figure out if you're hitting one server or a pool of them

| Tool              | What it's for                                                                    | Example / starter command                       | Used in lecture? |
|-------------------|----------------------------------------------------------------------------------|-------------------------------------------------|------------------|
| <b>wafw00f</b>    | Detects WAF signatures; many cloud load balancers (AWS ELB/ALB) show up here too | <code>wafw00f https://itpro.tv</code>           | YES              |
| <b>curl -I</b>    | Grab response headers to spot CDN/LB fingerprints (Server, Via, X-Cache)         | <code>curl -I https://itpro.tv/</code>          | YES              |
| <b>Nmap (-sV)</b> | Service/version/banner grabbing — sometimes leaks LB software directly           | <code>nmap -sV -p 80,443 itpro.tv</code>        | YES              |
| <b>httpie</b>     | Friendlier alternative to curl for quick header/response inspection              | <code>http HEAD https://itpro.tv</code>         | ADD              |
| <b>CloudFlair</b> | Attempts to find the real origin IP behind a Cloudflare-fronted site             | <code>python cloudflair.py -d target.com</code> | ADD              |

## 3 — WAF Detection & Fingerprinting

Know the filtering rules before you test the application

| Tool                     | What it's for                                                                                               | Example / starter command                      | Used in lecture? |
|--------------------------|-------------------------------------------------------------------------------------------------------------|------------------------------------------------|------------------|
| wafw00f                  | The standard WAF-fingerprinting tool; matches responses against a signature DB                              | wafw00f -a https://itpro.tv                    | YES              |
| Nmap NSE                 | http-waf-detect / http-waf-fingerprint scripts test WAF presence & identity                                 | nmap -p80,443 --script http-waf-detect <host>  | YES              |
| curl (headers & cookies) | Manual check for WAF-issued cookies (incap_ses_, AWSALB, __cfduid) and security headers                     | curl -v https://itpro.tv/   grep -i set-cookie | YES              |
| WhatWaf                  | Actively probes with test payloads to identify AND suggest bypass techniques for the detected WAF           | whatwaf -u https://target.com                  | ADD              |
| Nikto                    | Web server scanner that also flags WAF/IDS presence as part of its checks                                   | nikto -h https://target.com                    | ADD              |
| Burp Suite               | Industry-standard intercepting proxy; lets you manually study how a WAF alters/blocks requests in real time | Proxy tab -> intercept -> forward/modify       | ADD              |
| OWASP ZAP                | Free/open-source alternative to Burp; includes automated WAF-aware active scanning                          | zap-cli quick-scan https://target.com          | ADD              |

## 4 — Network Firewall Detection & Evasion Testing

Probe the perimeter's filtering rules

| Tool                 | What it's for                                                                                                   | Example / starter command                     | Used in lecture? |
|----------------------|-----------------------------------------------------------------------------------------------------------------|-----------------------------------------------|------------------|
| firewalk             | TTL-expiry technique to map which ports are reachable past a gateway/firewall                                   | firewalk -pTCP -d 80 <gw> <target>            | YES              |
| Nmap NSE (firewalk)  | Built-in Nmap script that reproduces the firewalking technique                                                  | nmap --script firewalk <target>               | YES              |
| Nmap evasion flags   | -f (fragment), -D (decoys), -g (source port) test how the firewall reacts to unusual packet shapes              | nmap -f -D RND:5 <target>                     | YES              |
| hping3               | Custom packet crafting — build unusual TCP/UDP/ICMP probes to test ACL behavior in detail                       | hping3 -S -p 80 <target>                      | ADD              |
| traceroute / tracert | Maps the network path hop-by-hop; sudden silent hops can indicate a filtering device                            | traceroute target.com                         | ADD              |
| Scapy                | Python packet-crafting library for building fully custom firewall-probing packets beyond what Nmap/hping3 offer | scapy>>><br>sr1(IP(dst=target)/TCP(dport=80)) | ADD              |

## 5 — Antivirus & Endpoint Defense Detection

Confirm presence without building evasive payloads

| Tool                                 | What it's for                                                                                       | Example / starter command                         | Used in lecture? |
|--------------------------------------|-----------------------------------------------------------------------------------------------------|---------------------------------------------------|------------------|
| <b>EICAR test file</b>               | Industry-standard harmless string that any real AV will flag — safe way to confirm AV is active     | download official EICAR .txt, observe AV response | YES              |
| <b>Sysinternals Autoruns</b>         | Lists startup entries/services on Windows — usually names the installed AV product directly         | Autoruns64.exe (GUI)                              | ADD              |
| <b>Sysinternals Process Explorer</b> | Shows running processes/services; spot AV process names (MsMpEng.exe, etc.)                         | procexp64.exe (GUI)                               | ADD              |
| <b>Nmap NSE (smb-enum-*)</b>         | On authorized internal engagements, some NSE scripts enumerate installed software/services over SMB | nmap --script smb-enum-services <host>            | ADD              |
| <b>Traffic analysis (Wireshark)</b>  | Capture and inspect outbound traffic for AV vendor update-server connections                        | wireshark (GUI) — filter by known AV domains      | ADD              |

## 6 — All-in-One Recon & Scanning Suites

What working pentesters run to tie everything above together

| Tool                   | What it's for                                                                                                    | Example / starter command            | Used in lecture? |
|------------------------|------------------------------------------------------------------------------------------------------------------|--------------------------------------|------------------|
| <b>Nmap</b>            | The core scanner — ports, services, OS fingerprinting, and dozens of NSE detection scripts (WAF, firewall, more) | nmap -A -T4 <target>                 | YES              |
| <b>Masscan</b>         | Extremely fast port scanner for large IP ranges — used to find live hosts before deeper Nmap scans               | masscan -p1-65535 <cidr> --rate 1000 | ADD              |
| <b>Recon-ng</b>        | Modular web recon framework — automates OSINT, subdomain, and infrastructure discovery in one console            | recon-ng > marketplace install all   | ADD              |
| <b>theHarvester</b>    | OSINT tool for emails, subdomains, IPs, and names tied to a target organization                                  | theHarvester -d target.com -b all    | ADD              |
| <b>Shodan / Censys</b> | Internet-wide device/service search engines — great for discovering exposed infrastructure and misconfigurations | shodan search 'org:"Target Inc"'     | ADD              |
| <b>Burp Suite Pro</b>  | The industry-standard web app testing platform — proxy, scanner, repeater, intruder all in one                   | GUI-driven                           | ADD              |

Always confirm you have written authorization before pointing any of these tools at a target. "YES" rows come straight from your WAFW00F/Nmap lab session and the IT Pro TV lecture; "ADD" rows are common next-step tools professionals layer in as they move from junior to mid-level recon work.